MAPPET

Plano de Segurança

Incremento atual: UC01 a UC11
Java + Spring Boot + Oracle
Novembro de 2026

Este plano mostra o que o MAPPET precisa proteger e como cada regra de segurança será garantida no back end em Java com Spring Boot. O foco está em dois pontos: o tratamento de dados pessoais conforme a LGPD (Lei nº 13.709/2018) e a proteção de crianças e adolescentes. Um sistema que coloca desconhecidos em contato por causa de animais atrai o público infantil e pode ser usado por adultos mal intencionados como pretexto para se aproximar de uma criança ou da família dela.

Como ler este plano. Nenhuma medida deste plano altera o MER, o MLR ou o script DDL. As marcadas com `NOVA` ainda não estão nos casos de uso: são aplicadas no código e na interface, ou usam colunas que já existem no modelo, como as datas de publicação, de cadastro e de interesse.

1 O que precisamos proteger

Quadro 1: Dados que exigem cuidado

Dado	Onde fica (MLR)	Por que proteger
Senha	`T_MAPPET_USUARIO.SENHA_HASH`	Muita gente usa a mesma senha em outros sites
E-mail e telefone	`T_MAPPET_USUARIO.EMAIL`, `TELEFONE`	São dados de contato; o do acolhedor só aparece pelo UC11 e é o principal alvo de quem quer abordar alguém fora do sistema
Nome	`T_MAPPET_USUARIO.NOME`	Identifica a pessoa
Fotos	arquivo apontado por `FOTO_URL`	Podem mostrar a casa, o rosto de quem publicou, uma criança ou a localização exata gravada no arquivo
Bairro	`BAIRRO` em publicação e animal	Junto com uma foto da fachada, pode levar até o endereço
Registro de interesse	`T_MAPPET_INTERESSE_ADOCAO`	Mostra quem recebeu o contato de cada acolhedor e quando; permite rastrear abandono, maus-tratos ou abordagem indevida

Fonte: elaborado pelas autoras (2026), a partir do MLR.

2 LGPD: como o MAPPET trata os dados pessoais

2.1 Finalidade e base legal de cada dado

A LGPD exige que todo dado tenha uma finalidade definida e uma base legal do art. 7º. O MAPPET não coleta CPF, endereço completo nem dados sensíveis (art. 5º, II), e não usa dados para marketing nem os repassa a terceiros.

Quadro 2: Finalidade e base legal

Dado	Para que é usado	Base legal
Nome, e-mail e senha	Criar a conta e fazer login (UC01, UC02)	Execução de contrato, aceito no cadastro (art. 7º, V)
Telefone e e-mail do acolhedor	Ser mostrado a quem registrar interesse (UC11) ou encontrar o pet (UC05, UC06)	Execução de contrato (art. 7º, V), com aviso claro no cadastro de que o contato será exibido nesses casos

Dado	Para que é usado	Base legal
Fotos, nome do pet e bairro	Publicar e localizar animais (UC05 a UC08)	Execução de contrato (art. 7º, V)
Registro de interesse	Saber quem recebeu cada contato, para apurar abandono, maus-tratos ou abuso	Legítimo interesse (art. 7º, IX) e exercício regular de direitos (art. 7º, VI)

Fonte: elaborado pelas autoras (2026), a partir da Lei nº 13.709/2018.

2.2 Princípios aplicados no sistema

Quadro 3: Princípios do art. 6º e como o MAPPET os cumpre

Princípio	Como aparece no sistema
Finalidade	Os dados só servem para publicar, adotar e reencontrar animais. Nenhum relatório ou exportação usa os contatos para outro fim
Necessidade	Pede só o bairro, nunca rua e número. Os cards da Home e a vitrine não levam contato (UC03, UC09). O contato só sai pelo UC11
Transparência	Política de privacidade em linguagem simples, com link no cadastro e no rodapé. Antes do "Quero adotar", a tela avisa que o interesse fica registrado
Segurança	Senha com BCrypt, HTTPS, respostas por DTO, sessão com cookie `HttpOnly` e `Secure`
Prevenção	Remoção da localização gravada nas fotos, limite de registros de interesse por dia e denúncia em todas as telas de conteúdo
Não discriminação	Nenhuma regra de busca ou de adoção usa dados pessoais para filtrar pessoas
Responsabilização	Este plano, o checklist da seção 5 e os testes documentam cada controle

Fonte: elaborado pelas autoras (2026).

2.3 Direitos do titular

O art. 18 garante ao usuário acesso, correção, exclusão e portabilidade dos próprios dados. O MAPPET atende esses pedidos pela própria conta, sem depender de contato manual. Pedidos de confirmação e acesso completos são respondidos em até 15 dias (art. 19, II).

Quadro 4: Direitos do art. 18 e rotas que os atendem

Direito	Rota	Comportamento
Acesso e portabilidade NOVA	`GET /minha-conta/dados`	Devolve um JSON com dados da conta, publicações, animais e interesses registrados, sem o `SENHA_HASH`
Correção NOVA	`PUT /minha-conta`	Altera nome, telefone e e-mail com as mesmas validações do UC01
Exclusão NOVA	`DELETE /minha-conta`	Apaga a conta, as publicações e as fotos. Os registros de interesse ficam guardados só pelo prazo do Quadro 5, com base no art. 16, I, e depois são apagados
Informação e revogação	Política de privacidade	Explica com quem o contato é compartilhado e como encerrar a conta a qualquer momento

Fonte: elaborado pelas autoras (2026).

2.4 Por quanto tempo os dados ficam guardados

Dado sem prazo de exclusão vira risco sem utilidade. Os prazos abaixo respeitam a RN04, que mantém o anúncio ativo até o tutor encerrá-lo, e usam as colunas de data que já existem no modelo. Um job agendado

com `@Scheduled` aplica o prazo do registro de interesse. Os prazos são uma proposta da equipe e podem ser ajustados.

Quadro 5: Prazos de retenção NOVA

Dado	Prazo	Depois do prazo
Conta	Enquanto o usuário mantiver a conta	Apagada quando ele pedir
Publicação de pet perdido ou encontrado	Enquanto o anúncio estiver ativo (RN04)	Apagada, com a foto, quando o tutor pedir ou quando o anúncio for encerrado (RF06)
Animal para adoção	Enquanto estiver disponível	Apagado, com a foto, quando o acolhedor pedir a retirada
Registro de interesse	2 anos a partir de `DATA_INTERESSE`	Apagado

Fonte: elaborado pelas autoras (2026).

2.5 Fotos sem localização escondida

Fotos tiradas pelo celular costumam levar no arquivo a latitude e a longitude de onde foram feitas. Mesmo pedindo só o bairro, o MAPPET entregaria o endereço exato a qualquer um que baixasse a imagem. Por isso o back end regrava toda foto antes de salvar, o que descarta esses metadados:

```
// regravar a imagem com ImageIO descarta os metadados EXIF, incluindo o GPS
BufferedImage imagem = ImageIO.read(arquivo.getInputStream());
ImageIO.write(imagem, formato, destino);   // formato: "jpg" ou "png"
```

2.6 Incidente de segurança

Se houver vazamento ou acesso indevido (art. 48), a equipe segue quatro passos: conter o problema, avaliar quais dados e quantas pessoas foram afetados, comunicar a ANPD e os titulares em até 3 dias úteis quando houver risco relevante (Resolução CD/ANPD nº 15/2024) e registrar o que aconteceu e o que foi corrigido. A política de privacidade divulga um e-mail de contato para assuntos de privacidade, que faz o papel do canal do encarregado (art. 41).

3 Segurança infantil e prevenção contra predadores

O MAPPET não é feito para crianças, mas animais atraem esse público, então o acesso de menores é provável. Isso coloca o sistema sob o Estatuto da Criança e do Adolescente (Lei nº 8.069/1990) e o ECA Digital (Lei nº 15.211/2025, em vigor desde 17 de março de 2026), que exige verificação de idade que não dependa só da palavra do usuário. A estratégia tem três camadas: manter menores fora do sistema, reduzir as oportunidades de um adulto abordar alguém de forma privada e agir rápido quando houver denúncia.

3.1 Riscos e medidas

Quadro 6: Riscos ligados a crianças e como o sistema responde

Risco	Como pode acontecer	Medida
Criança cria conta	Informa uma idade falsa no cadastro para publicar o próprio pet perdido ou adotar um animal	Cadastro só para maiores de 18 anos, com declaração e aceite dos termos como condição para concluir o cadastro NOVA. Na versão publicada, verificação por serviço especializado (documento ou estimativa de idade), já que a autodeclaração sozinha não atende o ECA Digital

Risco	Como pode acontecer	Medida
Falso pet encontrado usado como isca	Alguém diz ter achado o animal de uma família e marca a entrega em lugar isolado, contando com que uma criança vá buscar	Aviso fixo na tela de contato: entrega sempre em local público, por um adulto, nunca com criança sozinha, e conferir antes uma foto atual do animal NOVA
Coleta de contatos em massa	Um perfil registra interesse em muitos animais só para juntar telefones e e-mails	Antes de gravar um novo interesse, o back end conta os registros do usuário nas últimas 24 horas pela coluna `DATA_INTERESSE` e bloqueia a partir de 10 NOVA
Foto que expõe criança	Publicação com criança no colo do animal, uniforme escolar ou fachada da casa	Regra nos termos e aviso no envio da foto; remoção pela equipe quando denunciada NOVA
Material de abuso ou exploração infantil	Upload de imagem criminosa disfarçada de foto de animal	Remoção imediata, conta excluída, evidência preservada com acesso restrito e comunicação às autoridades. A imagem nunca é reenviada nem exibida a outros usuários NOVA
Abordagem pelo texto	A descrição do animal leva convites, links ou contatos para tirar a conversa do sistema	O campo `DESCRICAO` recusa telefones, e-mails e links; casos duvidosos são revisados pela equipe NOVA

Fonte: elaborado pelas autoras (2026), a partir da Lei nº 8.069/1990 e da Lei nº 15.211/2025.

Uma decisão de projeto também ajuda: o MAPPET não tem chat interno. O contato só é liberado entre adultos, depois de um registro que fica gravado com data, e cada liberação deixa rastro em `T_MAPPET_INTERESSE_ADOCAO`. Isso reduz conversas privadas sem histórico dentro da plataforma.

3.2 Denúncia e moderação

Toda publicação, todo animal e todo perfil exibem a orientação para denunciar pelo e-mail de contato da plataforma NOVA. Ao receber uma denúncia de risco a criança ou de conteúdo impróprio, a equipe retira o conteúdo do ar na hora, analisa o caso e, se confirmado, exclui a conta, preserva as evidências e comunica a Polícia Civil, a SaferNet Brasil ou o Disque 100, conforme a gravidade. Se a denúncia não se confirmar, o conteúdo volta ao ar. O denunciante recebe só o resultado, nunca dados do denunciado.

```
-- quantos interesses o usuário registrou nas últimas 24 horas (seção 3.1)
SELECT COUNT(*) FROM T_MAPPET_INTERESSE_ADOCAO
 WHERE ID_USUARIO = ?
   AND DATA_INTERESSE > SYSTIMESTAMP - INTERVAL '1' DAY;
```

Medidas mais avançadas, como a verificação de idade por serviço especializado e uma área de moderação dentro da plataforma, serão avaliadas nos próximos Projetos Integradores.

3.3 Avisos na interface

- **Cadastro (UC01):** o MAPPET é só para maiores de 18 anos; o contato informado será mostrado a quem registrar interesse nos seus animais.
- **Envio de foto (UC07):** mostre só o animal; evite crianças, uniformes, placas e a frente da casa.
- **Contato liberado (UC11):** combine o encontro em local público, vá acompanhado de um adulto, nunca envie uma criança e denuncie se algo parecer estranho.

4 Regras dos documentos e como o sistema garante cada uma

Quadro 7: Regras de segurança previstas nos documentos de referência

Regra	Origem	Como o sistema garante
Senha armazenada de forma criptografada, nunca em texto puro	UC01 passo 7 RF01, RNF02; MLR	O back end grava apenas o hash da senha, gerado com o `BCryptPasswordEncoder` do Spring Security, na coluna `SENHA_HASH`
Um e-mail só pode ter uma conta	UC01 E2; MLR	Coluna `EMAIL` com `UNIQUE`; a API avisa que o e-mail já existe e sugere o login
Login por e-mail e senha, informando que "e-mail ou senha estão incorretos"	UC02 E2 RF07, RN01	A mensagem é a mesma para os dois casos, sem dizer qual dos dois está errado
Usuário pode sair da conta a qualquer momento	UC02 A2	A rota de logout invalida a `HttpSession` no servidor
Home, publicações e área de adoção só para quem fez login	UC02, UC03, UC05, UC06, UC09, UC10, UC11	O `LoginInterceptor` bloqueia essas rotas e responde 401 sem login
Na página de login, só o botão "Adote aqui" e alguns animais em destaque	UC09 RN07	`GET /adocao/vitrine` é a única rota de adoção aberta e devolve só foto, nome e espécie; a lista completa (`GET /adocao`) exige login
Contato do acolhedor só depois de registrar o interesse	UC11 RN07	`POST /adocao/{id}/interesse` grava adotante, animal e data em `T_MAPPET_INTERESSE_ADOCAO` e só então devolve o contato
Um registro de interesse por adotante e animal	UC11 A2; MLR	Chave primária composta (`ID_USUARIO`, `ID_ANIMAL`); se o interesse já existe, a API só mostra o contato de novo
Toda publicação, todo animal e todo interesse pertencem a uma conta	UC05, UC06, UC10, UC11 RF02, RF03; MLR	`ID_USUARIO NOT NULL`, preenchido com o usuário da sessão, nunca com um valor vindo do formulário
Foto só em JPG ou PNG, até 5 MB	UC07 E1 RNF06, RNF08; MLR	O `MultipartFile` é conferido pelo tipo e pelos primeiros bytes do arquivo, com limite de 5 MB no `application.properties`; o arquivo é salvo com nome gerado pelo sistema e sem metadados (seção 2.5)
Nome, espécie, bairro e foto obrigatórios; nome e bairro sem números e não só espaços; espécie da lista	UC08 RN02; MLR	Anotações do Bean Validation (`@NotBlank`, `@Pattern`, `@Size`) com `@Valid`; o back end valida de novo tudo o que o site já validou
Cadastro: nome sem números, e-mail válido, telefone só com números	UC01 passo 5, E1	Mesma validação no site e no back end (`@Email`, `@Pattern`)
Cards da Home mostram foto, nome, espécie, bairro e tipo	UC03 RF04	A resposta da Home usa um DTO só com esses campos; e-mail e telefone de quem publicou não são enviados

Fonte: elaborado pelas autoras (2026), a partir dos casos de uso, do MER e do MLR.

5 Cuidados técnicos da implementação

Estes cuidados não mudam nenhuma regra dos documentos. São a forma correta de programar o que já está previsto:

- **Consultas com parâmetros**, para evitar SQL injection (alguém digitar um comando SQL num campo do formulário). Com Spring Data JPA, os métodos do repository já usam parâmetros:

```
// errado: o texto digitado vira parte do SQL
String sql = "SELECT * FROM T_MAPPET_USUARIO WHERE EMAIL = '" + email + "'";

// certo: o Spring Data JPA monta a consulta com parâmetro
Optional<Usuario> findByEmail(String email);
```

- **Senhas do sistema fora do GitHub.** O `application.properties` lê a senha do banco de uma variável de ambiente (`${DB_PASSWORD}`), sem escrever a senha real no arquivo.
- **Respostas sem dados demais.** As rotas devolvem DTOs, nunca a entidade inteira, para o `SENHA_HASH` e os contatos não vazarem por engano.
- **Limite de tentativas** NOVA no login, no cadastro e no registro de interesse, para dificultar robôs e abuso.
- **Logs sem dados pessoais.** O log da aplicação registra o ID do usuário, nunca senha, e-mail ou telefone.
- **HTTPS** quando o site for publicado na internet, para que senha e dados não trafeguem abertos.
- **Dados fictícios nos testes**, nunca dados de pessoas reais, e nunca imagens de crianças reais.

6 Checklist antes da entrega

Regras atuais

- [ ] Senhas no banco aparecem como hash (começam com `$2a$`), nunca legíveis (UC01)
- [ ] Cadastrar duas vezes o mesmo e-mail é recusado (UC01 E2)
- [ ] Senha errada e e-mail inexistente mostram a mesma mensagem (UC02 E2)
- [ ] Abrir a Home, publicar ou abrir a área de adoção sem login devolve erro 401 (UC03, UC05, UC06, UC09, UC10)
- [ ] Sem login, a vitrine mostra só foto, nome e espécie (UC09)
- [ ] O contato do acolhedor só aparece depois do "Quero adotar", e o interesse fica gravado (UC11)
- [ ] Clicar de novo em "Quero adotar" no mesmo animal não cria outro registro (UC11 A2)
- [ ] Arquivo que não é JPG ou PNG, ou maior que 5 MB, é recusado (UC07 E1)
- [ ] Campos vazios, só com espaços ou com números são recusados pelo back end (UC08)
- [ ] Nenhuma consulta SQL junta texto digitado pelo usuário
- [ ] A senha do banco não está escrita no código nem no GitHub

LGPD

- [ ] O cadastro mostra a política de privacidade e só é concluído com o aceite
- [ ] Uma foto com GPS enviada pelo celular é salva sem nenhum metadado de localização
- [ ] `GET /minha-conta/dados` devolve todos os dados do usuário e nenhum dado de outra pessoa
- [ ] `DELETE /minha-conta` apaga conta, publicações e fotos
- [ ] O job de retenção apaga registros vencidos de acordo com o Quadro 5
- [ ] Nenhuma resposta da API e nenhum log da aplicação expõem senha ou contato fora do UC11

Segurança infantil

- [ ] O cadastro não é concluído sem a declaração de maioridade e o aceite dos termos
- [ ] O 11º registro de interesse nas últimas 24 horas é bloqueado
- [ ] Descrição com telefone, e-mail ou link é recusada
- [ ] A orientação de denúncia aparece em toda publicação, animal e perfil

- [ ] Os avisos de segurança aparecem no cadastro, no envio de foto e na tela de contato

---

Referências: casos de uso UC01 a UC11, MER e MLR do MAPPET; Lei nº 13.709/2018 (LGPD); Lei nº 8.069/1990 (Estatuto da Criança e do Adolescente); Lei nº 15.211/2025 (Estatuto Digital da Criança e do Adolescente); Resolução CD/ANPD nº 15/2024 (comunicação de incidente de segurança).